

Privacy-Preserving Audit Log Analysis for Insider Threat Detection in Financial Institutions

Omkar Kamble (C5056117) · MSc Cyber Security, Newcastle University · Supervisor: Dr Amy Nejati · CSC8209

ABSTRACT

Financial institutions rely on detailed audit logs to detect malicious insiders, yet those same logs are a persistent, identifiable record of the everyday behaviour of thousands of innocent employees, which sits uneasily with the data minimisation and storage limitation obligations of the GDPR. This dissertation asks a specific and answerable question: at what level of anonymisation does an audit log become defensible under the GDPR, and what does that privacy cost in detection performance? We design and implement a system that first establishes a raw-data detection ceiling using an Isolation Forest over behavioural features, then applies a formally verified k -anonymity generalisation module to four quasi-identifiers, namely identity, timestamp, resource and action, at $k \in \{2, 5, 10, 20\}$, re-running detection on each anonymised view. On a purpose-built synthetic UK financial-sector dataset of 500 employees, 25 malicious insiders and 850,853 log events, the raw baseline attains an F1 of 0.88 and an AUC of 0.995. Under anonymisation, ranking quality proves remarkably robust, remaining above 0.95 AUC even at $k = 20$, while thresholded F1 degrades gracefully to 0.72. We show that $k = 10$ is the practical sweet spot, since every record is then indistinguishable from at least nine others at only 5.4% information loss and no measurable loss of F1 relative to $k = 5$, and we map each configuration to the GDPR articles it satisfies. The central finding is that strong, provable anonymity and effective insider-threat detection are not mutually exclusive: the tension is real but quantifiable, and at moderate k comfortably manageable.

1 INTRODUCTION, RATIONALE AND OBJECTIVES

1.1 Problem and motivation

Insider threats are security incidents caused by employees or contractors who deliberately misuse legitimate system access to steal data, commit fraud, or cause harm, and they are among the most damaging and hardest to detect risks facing financial institutions. Unlike an external intrusion, malicious insider activity is generated by a principal who is already authenticated and already authorised, so it frequently looks indistinguishable from ordinary work [1, 2]. Industry studies consistently report that insider incidents take longer to contain than external ones and carry some of the highest per-incident remediation costs of any threat category. In the financial sector the consequences are especially acute, spanning regulatory penalties under the GDPR and the Financial Conduct Authority (FCA) framework, direct loss through fraud or data theft, and reputational damage that can outlast the incident by years. The distinctive difficulty of the insider case is the base-rate problem: in a workforce of thousands the malicious few are vastly outnumbered by benign staff whose legitimate work can look superficially similar, so a detector that is even slightly trigger-happy drowns analysts in false alarms, while one that is too conservative misses the incidents it exists to catch. That asymmetry is why this work reports ranking quality and full confusion counts rather than a single accuracy figure the class imbalance would render meaningless.

The primary technical mechanism for detecting such behaviour is the *audit log*: a continuous, automated record of employee actions spanning logon and logoff events, file access and transfer, email metadata, removable-media (USB) usage, and web activity. These logs are indispensable for anomaly detection and for the forensic reconstruction of an incident after the fact. However, the very property that makes them useful, namely completeness, also makes them a privacy liability. An audit log is, by construction, a granular and persistent record of everything every employee does throughout the working day, and the overwhelming majority of the people it records are doing nothing wrong.

This creates a genuine and presently unresolved legal and ethical conflict. Under the GDPR, in particular Article 5(1)(c) on data minimisation, Article 5(1)(e) on storage limitation and Article 25 on data protection by design, personal data must be adequate, relevant and limited to what is necessary, retained no longer than needed, and protected by appropriate technical measures from the outset [20]. Storing identifiable behavioural logs on an entire workforce indefinitely, on the off-chance that a handful are malicious, is difficult to reconcile with these principles. Organisations therefore face a dilemma they cannot presently resolve in a validated, practical way: they must monitor for insider threats, but doing so entails recording the private activity of thousands of innocent staff.

1.2 The privacy and security conflict in workplace monitoring

It is tempting to treat this as a purely legal problem to be solved with policy and consent forms, but the tension is fundamentally technical. Effective detection wants *more* data: finer timestamps, exact resource names, precise identities and long retention, because subtle malicious patterns emerge only against a rich behavioural background. Privacy law wants *less*: coarser data, shorter retention and the removal of anything not strictly necessary. The two objectives pull the same design levers in opposite directions, and existing practice resolves the conflict in favour of security, retaining everything and relying on access controls rather than data reduction. That leaves the residual risk intact, since a breach, an over-broad query or a change of purpose can expose the complete behavioural history of every employee. A technical middle path, reducing data to the point where re-identification is provably hard yet detection still works, has not been systematically characterised for this domain, and providing that characterisation is the purpose of this dissertation.

1.3 Research question and aim

The work is framed by one concrete research question:

At what level of anonymisation does privacy become satisfactory under the GDPR, and what is the corresponding cost to insider-threat detection performance?

Aim. To design, implement and evaluate a privacy-preserving audit log anonymisation system that satisfies GDPR data minimisation principles while retaining sufficient utility for insider-threat detection in financial-sector environments.

1.4 Objectives and measures of success

Answering the research question requires two numbers that do not currently exist in the literature for this domain: a credible measure of how well insider detection works on raw audit logs, and the same measure recomputed after the logs have been anonymised to a *provable* standard. The aim is therefore decomposed into five sequential SMART objectives, each supplying the input the next consumes. O1 establishes what is known and where the gap lies; O2 fixes the reference point against which every privacy configuration is compared; O3 builds the privacy mechanism; O4 combines the two into the tradeoff that is the central empirical result; and O5 translates that result into the regulatory language a compliance function works in. Each carries an explicit, falsifiable success measure, stated below with the reasoning behind it, so the project can be judged against a stated bar rather than an impression.

O1, Literature review.

Systematically review insider-threat detection, k -anonymity and related privacy-enhancing techniques, and GDPR employee-monitoring requirements, in order to justify the choice of detector and privacy model rather than assume them. *Measure*: at least 15 peer-reviewed sources synthesised into an explicitly stated research gap. *Rationale*: the gap claim is the premise of the whole project, so it must rest on a systematic rather than a selective reading.

O2, Baseline detection pipeline.

Construct a suitable dataset and implement unsupervised anomaly detection on raw, fully identified logs, establishing the performance ceiling that anonymisation can only degrade. *Measure*: a working baseline achieving $F1 \geq 0.75$ with documented precision, recall and AUC-ROC. *Rationale*: 0.75 is demanding enough to show the detector genuinely works, so that any later degradation is attributable to anonymisation and not to a weak starting point.

O3, Anonymisation system.

Implement a k -anonymity generalisation and suppression module over the four quasi-identifiers, namely identity, timestamp, resource and action, at $k \in \{2, 5, 10, 20\}$. *Measure*: the achieved k independently verified in code at all four configurations. *Rationale*: the privacy claim must be *proven* on the released data, not asserted by the component that produced it; the four values span weak to strong anonymity on a roughly logarithmic scale.

O4, Privacy and utility tradeoff.

Re-run detection using only anonymised columns at each k and measure detection performance and information loss on the same pipeline. *Measure*: a quantitative tradeoff curve terminating in a single recommended deployment configuration. *Rationale*: this is the objective that answers the research question; re-detecting on the anonymised view, rather than scoring the anonymisation in isolation, is what makes the measurement operationally meaningful.

O5, GDPR compliance assessment.

Map the system's properties at each k onto specific GDPR articles, stating where each configuration does and does not satisfy them. *Measure*: a structured, article-by-article compliance analysis covering every

configuration. *Rationale*: a tradeoff curve alone does not tell a firm what k to choose; converting k into a documented regulatory posture is what makes the result actionable.

All five objectives were met in full. Section 4 reports the outcomes for O2 to O4 against the measures above, Section 5.2 discharges O5, and Section 2 discharges O1.

1.5 Scope and threat model

The project scope is deliberately bounded so that its claims are defensible. The adversary of interest is the *malicious insider*: an authorised employee who exfiltrates sensitive data through file copies, email, removable media or web uploads. Negligent and compromised insiders are acknowledged but not the primary target, since their signatures differ. On the privacy side, the adversary is a party with access to the anonymised log who attempts to *re-identify* an individual by linking quasi-identifiers to external knowledge. The protection goal is therefore to bound identity disclosure, which is exactly what k -anonymity formalises. The system operates on data *at rest* for analysis, rather than in real time, which matches how forensic and periodic insider-risk reviews are conducted in practice. Detection is performed per employee over an analysis window rather than per event, because insider risk is a behavioural pattern over time, not a single action.

1.6 Contributions

This dissertation makes four contributions: a *constructive artefact*, an end-to-end reproducible pipeline that anonymises financial audit logs and re-runs detection on the anonymised data, with an interactive tool for exploring the result; an *empirical tradeoff characterisation*, the first quantitative privacy and utility curve for k -anonymised insider detection over a financial-sector audit log; a *GDPR mapping* tying each k to the articles it does and does not satisfy; and a *reproducible dataset generator* embedding subtle insiders and legitimate-outlier personas so the tradeoff is non-trivial rather than saturated.

1.7 CyBOK alignment

The project maps onto three knowledge areas of the Cyber Security Body of Knowledge (CyBOK v1.1). *Adversarial Behaviours* (AB) covers the insider-threat detection component, specifically the taxonomy of malicious insider actors and log-based behavioural detection methods, which supply the threat model of Section 1.5 and the detector of Section 3.6. *Privacy and Online Rights* (POR) covers the core technical contribution, namely the application of k -anonymity and related privacy-enhancing technologies to audit-log data and the assessment of GDPR data-minimisation compliance, developed in Sections 3.7 and 5.2. *Authentication, Authorisation and Accountability* (AAA) is engaged because audit logs are the primary accountability mechanism in enterprise systems, so the question of how much forensic and detective utility survives anonymisation maps directly onto AAA's treatment of audit and logging. The central research question, namely how to satisfy GDPR obligations (POR) while maintaining insider-threat detection capability (AB) through privacy-preserving audit-log design (AAA), sits deliberately at the intersection of these three areas, and the contribution is precisely the interface between them rather than a deeper result within any one.

1.8 Ethical, legal and professional considerations

The project is privacy-motivated, but a monitoring tool is inherently dual-use, and this shaped its design. No human participants are involved and all experiments use a fully synthetic dataset containing no real personal data, so the direct ethical risk is low and ethics approval was obtained through NESS. Two broader considerations were addressed in the design itself. The first is the dual-use risk that a system anonymising monitoring data could legitimise more invasive surveillance under a veneer of compliance, mitigated through the GDPR assessment of Section 5.2, which identifies where even anonymised monitoring may exceed lawful processing limits. The second, following Cavoukian [19], is that privacy is embedded architecturally, so the anonymisation module is the primary contribution rather than a bolt-on. Professionally, the work follows the BCS Code of Conduct's duty to have regard to the legitimate rights of third parties, here the monitored employees; legally, it is framed by the GDPR and by the FCA's record-keeping expectations, which require robust monitoring but do not license disproportionate processing.

The remainder is organised as follows. Section 2 reviews the two research streams; Section 3 sets out the methodology, architecture and pipeline; Section 4 reports the dataset, baseline, k -anonymity verification and tradeoff; Section 5 evaluates the results and gives the GDPR assessment, deployment guidance and limitations; Section 6 concludes.

2 LITERATURE REVIEW

The project sits at the intersection of two mature but largely separate research streams, insider-threat detection and privacy-preserving data publishing, together with the regulatory literature that motivates their union. This section reviews each in turn and then positions the present work against them.

2.1 Insider-threat detection

Homoliak et al. [1] provide the most comprehensive recent survey, categorising insiders as malicious, negligent or compromised and organising detection into host-based, network-based and log-based approaches. This project targets the malicious category, the greatest risk in financial environments, and log-based detection, the dominant technical approach in enterprise settings. Salem et al. [2] and Liu et al. [3] repeatedly note two structural difficulties: genuine incidents are extremely rare, so labelled training data is scarce, and the base rate of malicious activity is minuscule, so even a low false-positive rate generates unmanageable alert volumes.

These difficulties motivate *unsupervised anomaly detection*, which learns a model of normal behaviour and flags deviations without needing labelled attacks. Chandola et al. [4] give the canonical taxonomy of anomaly-detection techniques and their assumptions. Tuor et al. [5] demonstrate unsupervised deep-learning detection of insiders in structured log streams, while Legg et al. [6] build user- and role-based behavioural profiles and score deviations from them. Yuan and Wu [22] review the deep-learning branch of this literature specifically and observe that, despite strong reported results, almost all of it is evaluated on raw, fully identified log data, which is precisely the assumption this dissertation relaxes. The Isolation Forest of Liu, Ting and Zhou [7] is particularly well suited to this problem: it isolates anomalies directly rather than modelling normality, has near-linear time complexity, requires no distance metric, and handles the high-dimensional, mixed-scale behavioural feature vectors typical of audit data. These properties are the reason it is adopted as the detector in this work. Sommer and Paxson [8] provide an essential cautionary counterpoint, arguing that machine learning for security anomaly detection is often undermined by unrealistic evaluation and by the operational cost of false positives. Their critique directly informs two decisions here: to report AUC-ROC and a full confusion matrix rather than accuracy alone, and to engineer legitimate outlier personas into the evaluation data so that the detection task is not artificially easy.

A less frequently acknowledged difficulty concerns evaluation data rather than method. Because genuine incidents are commercially sensitive and legally protected, the field depends on a few shared corpora, above all the CERT synthetic dataset of Glasser and Lindauer [18], still the de facto benchmark a decade on. This monoculture has two consequences here. Reported figures are only weakly comparable across studies, because authors select different CERT versions, windows and aggregation granularities, so an F1 of 0.9 in one paper and 0.8 in another may reflect task difficulty rather than method quality. More consequentially, CERT models a generic US organisation and encodes neither the role structure of a UK financial institution nor the regulatory framing that makes anonymisation necessary. Legg et al. [6] and Tuor et al. [5] both evaluate on CERT and report strong results, yet neither asks whether those results survive any reduction in data fidelity, which is precisely the question motivating this work.

It is also worth stating why an Isolation Forest is preferred to the deep sequence models dominating recent work [5, 22]. The comparison is not primarily one of accuracy: deep models report higher headline figures, but they consume event order and fine-grained temporal structure, need substantially more data to train stably, and are difficult to explain to the compliance audience this work addresses. The Isolation Forest consumes a fixed per-entity aggregate vector, trains unsupervised in near-linear time, and yields a score that decomposes into interpretable feature contributions. That choice is deliberately conservative and not cost-free, a point returned to in Section 5: an aggregate-feature model is by construction the detector family least disturbed by generalising individual event attributes, so it is a favourable rather than a worst case for the central finding.

2.2 Privacy-preserving data publishing

The second stream provides the anonymisation machinery. Samarati [9] and Sweeney [10] introduced *k-anonymity*, which requires every record to be indistinguishable, over a set of *quasi-identifiers* (QIDs), from at least $k - 1$ others, so that the probability of re-identification through those attributes is bounded by $1/k$. In practice *k-anonymity* is achieved by *generalisation*, which replaces specific values with broader categories, and by *suppression*, which removes residual records that cannot be grouped, navigating a lattice of possible generalisations. LeFevre et al.'s Incognito [11] is a foundational full-domain algorithm for this search, and Xu et al. [15] introduce utility-based local recoding that explicitly minimises information loss rather than treating all generalisations as equal.

Two well-known limitations of *k-anonymity* are important for an honest assessment. Machanavajjhala et al. [12] showed that *k-anonymity* alone remains vulnerable to *attribute disclosure* when an equivalence class is homogeneous in a sensitive attribute, and proposed *ℓ -diversity* as a remedy. Li et al. [13] refined this further with *t -closeness*, which constrains the distribution of the sensitive attribute within each class. Fung et al. [14] survey the broader field and compare these models and their tradeoffs. The present work implements and verifies *k-anonymity* as its privacy mechanism, and treats *ℓ -diversity* and *t -closeness* as the natural next layer, discussed in the evaluation. It is worth noting where log-based detection sits among the broader family of insider-detection paradigms. Psychological and sentiment-based approaches infer intent from communications, and graph-based approaches model relationships between users and resources; both raise arguably sharper privacy concerns, since they analyse the content and social structure of employee activity rather than its aggregate shape. Log-based

behavioural detection is attractive precisely because it can operate on metadata and coarse aggregates, which makes it the paradigm most amenable to the anonymisation this project studies.

The critical observation for this dissertation is that essentially all of this machinery was designed for, and evaluated on, *static microdata*: a census extract or hospital discharge table in which each individual contributes exactly one row and the release is consumed by aggregate statistical queries. Audit logs violate both assumptions. An individual contributes thousands of rows, so the equivalence classes k -anonymity reasons about are populated by events rather than people, and event-level anonymity is not the same thing as person-level anonymity. The consumer is also not a statistical query but a detector operating on per-entity aggregates, so information loss measured on the released table is only loosely predictive of utility loss at the point of use. The literature offers little on this mismatch: network-trace anonymisation addresses a superficially similar problem, but it protects topology and host identity against traffic analysis rather than the behavioural profile of a named employee, and it offers no formal disclosure guarantee. A practitioner wishing to anonymise an audit log therefore has well-founded theory for the mechanism but no evidence about what it costs the application, which is exactly the gap this project fills.

2.3 Privacy and information-loss metrics

Quantifying the cost of anonymisation requires a principled information-loss metric. Wagner and Eckhoff [16] give the definitive survey of technical privacy metrics, spanning adversarial, information-theoretic and data-similarity families. From it we adopt the *Normalised Certainty Penalty* (NCP), due to Xu et al. [15], which measures for each generalised attribute the fraction of the value domain a generalised value now covers, averaged across the QIDs. NCP yields a single comparable value in $[0, 1]$, where 0 is no generalisation and 1 complete loss of an attribute's information, and reporting it alongside detection metrics is what allows the tradeoff to be stated quantitatively rather than impressionistically.

2.4 Regulatory framing: the GDPR and employee monitoring

The regulatory motivation draws on the GDPR itself and on practitioner analyses of its business impact [20, 21], together with Cavoukian's Privacy by Design [19]. A crucial legal nuance, explicit in Recital 26, is the distinction between *pseudonymisation*, where data can still be attributed to an individual with additional information and so remains personal data in scope, and true *anonymisation*, where re-identification is no longer reasonably likely and the data falls outside the Regulation. k -anonymity is one of the few techniques with a formal, testable claim to move data along that spectrum, which is what makes it attractive for audit logs. The Article 29 Working Party's Opinion 05/2014 [24] is the authoritative regulatory reading of that threshold and is deliberately demanding: it assesses each technique against three residual risks, namely *singling out*, *linkability* and *inference*, and notes that generalisation-based methods address singling out well but bound linkability and inference only partially. That assessment is adopted here as the standard against which the claims in Section 5.2 are hedged. Monitoring is further constrained by proportionality: even with a lawful basis it must be no more intrusive than necessary, a principle a tunable anonymity level operationalises directly. UK Information Commissioner's Office guidance [25] reinforces this, requiring employers to identify a lawful basis, be transparent, and ensure monitoring is necessary and proportionate to a specified purpose. A technique that lets an organisation dial the intrusiveness of retained data up or down, and evidence the choice, turns what is often a binary policy argument into a documented, defensible engineering position.

2.5 Alternative privacy models

k -anonymity is not the only candidate, so it is worth stating why it was chosen. *Differential privacy* [23] offers a stronger, composable, attack-agnostic guarantee by adding calibrated noise to query results, but it fits poorly here: insider detection consumes the individual per-employee record rather than an aggregate query, and injecting noise into each employee's features would corrupt precisely the rare-event signal detection depends on. k -anonymity instead preserves truthful records while bounding re-identification, keeping the anomaly structure intact. *Encryption and access control* protect data in transit and at rest without reducing what is retained, so they do not address the data-minimisation obligation motivating the project. Finally, this work uses *global* rather than *local* recoding because it is simpler to verify and reason about legally; local recoding [15] typically achieves lower loss and is a promising extension.

2.6 Positioning and the research gap

Table 1 situates this work against representative prior art. The two streams are each well studied but almost never together, and never, to our knowledge, with a validated quantitative framework for anonymising *financial-sector audit logs* while preserving detective utility. This dissertation closes that gap by measuring both sides of the tradeoff on the same pipeline and expressing the result in terms a compliance function can act on.

Table 1. Positioning against representative prior work. Only the present work evaluates detection and formal anonymity jointly on the same audit-log pipeline.

Work	Detection	Formal privacy	Tradeoff
Homoliak et al. [1]	✓	✗	✗
Yuan and Wu [22]	✓	✗	✗
Tuor et al. [5]	✓	✗	✗
Legg et al. [6]	✓	✗	✗
Sweeney [10]	✗	✓	✗
Machanavajjhala et al. [12]	✗	✓	✗
Fung et al. [14]	✗	✓	~
This work	✓	✓	✓

3 SYSTEM DESIGN AND METHODS

This section describes the methodology, the system architecture, and each component of the pipeline in the order in which data flows through it.

3.1 Methodology

The project follows a *constructive development and experimental evaluation* methodology: an artefact is built and then used as the instrument of a controlled experiment, which suits a causal question asking how a design parameter (k) affects two measurable outcomes. The work proceeds in four phases, namely dataset construction, baseline detection, anonymisation and tradeoff evaluation, corresponding to objectives O2 through O4. All code and data are version-controlled and every step seeded, so the reported numbers are exactly reproducible.

3.2 System architecture

The system is a linear pipeline of five components, shown in the box below. A *data layer* stores the unified log and employee table in a relational database; a *feature engineering* component aggregates raw events into a per-employee behavioural vector; an *anonymisation* component applies k -anonymity generalisation and suppression and verifies the result; a *detection* component fits the Isolation Forest and produces anomaly scores; and a Streamlit *presentation* component exposes both views, the results and the tradeoff to an analyst. Anonymisation sits deliberately between the data layer and detection, so a deployment can feed detection from anonymised rather than raw data, which is the operational scenario the experiment evaluates.

Unified log (DB) → Feature engineering (per employee) → [Anonymisation: generalise + suppress + verify k]
 → Isolation Forest → Scores, metrics, tradeoff → Streamlit dashboard

3.3 Dataset design and rationale

Real financial audit logs cannot lawfully be released for research, and the CERT corpus [18], though valuable, is US-oriented and not tailored to a UK financial institution’s role structure or GDPR framing. We therefore generated a purpose-built synthetic dataset whose schema mirrors an enterprise unified log. The generator is seeded for reproducibility and deliberately engineered so that the tradeoff is non-trivial, through two design features that stress the detector. First, the normal population is heterogeneous: alongside regular staff the generator injects legitimate-outlier archetypes, creating genuine false-positive pressure so the raw baseline lands realistically below a perfect score rather than trivially separating the classes. Second, insiders are subtle, performing small-chunk exfiltration mostly inside office hours and drawn from rare resource names that fall into small equivalence classes, so stronger anonymisation suppresses proportionally more of their distinguishing signal, which is exactly the effect the experiment measures. Table 2 summarises the resulting corpus.

Table 3 details the five behavioural archetypes used to build that heterogeneous normal population. Each perturbs a subset of the behavioural parameters in a direction overlapping with genuine insider indicators, which is what creates realistic false-positive pressure.

3.4 Feature engineering

Detection operates at the level of the entity (employee) rather than the individual event, because insider behaviour is a pattern over time. The raw log is aggregated per entity into the eight-dimensional feature vector of Table 4, encoding the classic indicators of abnormal working hours, unusual data movement and elevated access to sensitive resources. Ratios are preferred to raw counts wherever possible, so a busy but benign employee is not penalised for generating many events: what matters is the *shape* of activity, not its volume.

Table 2. Composition of the synthetic UK financial-sector audit-log dataset.

Property	Value
Employees (entities)	500
of which malicious insiders	25 (5.0%)
Observation window	180 days
Total log events	850,853
of which malicious events	9,206 (1.08%)
Departments / seniority tiers	8 / 3
Activity types	logon, web, file, email, USB
Behavioural features per entity	8

Table 3. Legitimate-outlier archetypes in the normal population and the benign behaviour that makes them resemble insiders.

Archetype	Distinguishing benign behaviour
Workaholic	Elevated after-hours and weekend activity
IT administrator	Heavy USB use and privileged high-sensitivity access
Heavy analyst	High copy-action ratio and data volume
External-facing	High external-web and email ratio
Occasional USB user	Sporadic removable-media use

Table 4. Behavioural features aggregated per employee and their insider rationale.

Feature	Insider rationale
After-hours ratio	Exfiltration often occurs outside core hours
External-activity ratio	Data leaving the internal perimeter
Avg / max / total volume	Bulk or unusual data movement
High-sensitivity ratio	Disproportionate access to sensitive files
USB events per day	Removable-media exfiltration channel
Copy-action ratio	Copying rather than merely reading

3.5 Evaluation metrics

Detection is a binary classification of each employee as insider or normal, and the metrics follow from the confusion-matrix counts of true positives (TP), false positives (FP) and false negatives (FN). Precision is the fraction of flagged employees who are genuine insiders, recall is the fraction of genuine insiders that are flagged, and their harmonic mean is the F1 score, as in Equations (1) and (2):

$$\text{Precision} = \frac{\text{TP}}{\text{TP} + \text{FP}}, \quad \text{Recall} = \frac{\text{TP}}{\text{TP} + \text{FN}}, \quad (1)$$

$$\text{F1} = \frac{2 \text{ Precision} \cdot \text{Recall}}{\text{Precision} + \text{Recall}}. \quad (2)$$

F1 balances the two in a single threshold-dependent number. Because F1 depends on where the decision threshold is set, we also report the area under the receiver operating characteristic curve (AUC-ROC), which integrates the true-positive rate against the false-positive rate over all thresholds and thus measures how well the anomaly score *ranks* insiders above normal staff independently of any operating point. As argued by Sokolova and Lapalme [17], reporting a threshold-free ranking metric alongside a threshold-dependent one is essential under heavy class imbalance, and the divergence between the two under anonymisation turns out to be one of the more informative results of this study.

One structural consequence of this protocol explains a pattern visible in every results table. The detector runs at a fixed contamination of 5%, so it flags exactly 25 of 500 entities and the dataset contains exactly 25 insiders. Predicted positives therefore equal actual positives, giving $\text{TP} + \text{FP} = \text{TP} + \text{FN} = 25$, which by Equations (1)–(2)

Table 5. Generalisation hierarchies for the four quasi-identifiers. Higher levels are more general and lose more information.

QID	Levels (specific → general)
Identity	department → division → any role
Timestamp	exact hour → 6-hour window → core / off hours → any time
Resource	exact resource → sensitivity class → any resource
Action	exact action → behavioural category → any action

forces precision, recall and F1 to coincide in every configuration and false positives to equal false negatives. Those three columns are consequently one quantity reported three ways, retained only for comparability with the literature, and this is the principal reason AUC-ROC is foregrounded as the only reported metric free of the constraint.

3.6 Baseline detection with Isolation Forest

The detector is an Isolation Forest [7] with 200 trees and a contamination parameter of 0.05, which matches the known 5% insider prevalence, trained unsupervised on the feature matrix. The forest isolates each entity x by recursive random splitting and scores it by the expected path length $E[h(x)]$ required to do so, normalised by $c(n)$, the average path length of an unsuccessful search in a binary tree of n points, as in Equation (3):

$$s(x, n) = 2^{-\frac{E[h(x)]}{c(n)}}. \quad (3)$$

Entities isolated in few splits are anomalous. In the scikit-learn implementation the sign is inverted, so a lower score denotes a more anomalous entity, and the 5% most anomalous are flagged as suspected insiders. Because detection is unsupervised, ground-truth labels are used only for evaluation and never for training, reflecting the operational reality that real insiders are not labelled in advance. Following Sommer and Paxson [8] and Sokolova and Lapalme [17], AUC-ROC is foregrounded alongside the threshold-dependent F1.

3.7 The k -anonymity anonymisation module

The core contribution is a generalisation-and-suppression module that transforms the log to satisfy k -anonymity over four QIDs, each with the hierarchy shown in Table 5. Formally, a released table T^* satisfies k -anonymity with respect to a QID set Q if every equivalence class E induced by Q contains at least k records, bounding the probability that an adversary linking on Q identifies an individual, as in Equation (4):

$$\min_{E \in T^*/Q} |E| \geq k \implies \Pr[\text{re-identification}] \leq \frac{1}{k}. \quad (4)$$

Identity is first pseudonymised with a salted one-way hash, removing direct identifiers while keeping per-entity aggregation possible, and the role attribute is then generalised. The exact timestamp, a direct re-identification vector, is always dropped, retaining only a coarse date for ordering, and time is generalised from an exact hour up to complete removal. Resource and action are generalised through their natural category hierarchies.

For a target k , the module performs global recoding, described in Algorithm 1. It enumerates the generalisation lattice ordered by total generalisation level, so the least-loss configuration is considered first, and computes the size of every QID equivalence class. Residual classes smaller than k are suppressed provided the total suppression rate stays within a 5% budget, and the first configuration satisfying k within budget is selected, yielding the minimum-information-loss anonymisation for that k . The result is then verified: k is confirmed to equal the smallest equivalence-class size over the QIDs, so the guarantee is proven programmatically rather than asserted.

The lattice for four QIDs contains a small, fixed number of configurations, so the search is inexpensive; the dominant cost is the per-configuration equivalence-class computation, a single group-by over the log and therefore near-linear in the number of events. The full four-value sweep over the 850,853-event log completes in well under a minute on a commodity machine, so the approach is practical at the scale of a mid-sized institution’s log.

Algorithm 1. k -anonymisation by minimum-loss global recoding

1. pseudonymise identities (salted hash)
2. for each config in lattice (least-general first):
3. generalise QIDs to that config
4. compute equivalence-class sizes
5. suppress classes with size $< k$
6. if suppression rate $\leq 5\%$: select and stop
7. verify min class size $\geq k$; compute NCP

Table 6. Baseline detection performance on raw logs, with the confusion matrix (500 entities, 25 insiders).

Metric	Value	Confusion matrix	
		Pred. Normal	Pred. Insider
Precision	0.88		
Recall	0.88	472 (TN)	3 (FP)
F1	0.88	3 (FN)	22 (TP)
AUC-ROC	0.995		

3.8 Information loss and privacy verification

Information loss is quantified with the Normalised Certainty Penalty. For a categorical attribute A_j generalised to a node covering m_j of M_j leaf values, the per-attribute penalty is $(m_j - 1)/(M_j - 1)$, and the configuration's NCP is the mean over the $d = 4$ QIDs [15, 16], as in Equation (5):

$$\text{NCP} = \frac{1}{d} \sum_{j=1}^d \frac{m_j - 1}{M_j - 1} \in [0, 1]. \quad (5)$$

Privacy verification is independent of anonymisation: it recomputes the equivalence classes from the output and reports the achieved k , the number of classes and their mean size, so the guarantee can be audited without trusting the generator. As a worked illustration, the timestamp attribute has a leaf domain of 24 hours; generalising an exact hour to a 6-hour window covers $m = 6$ of $M = 24$ values, a penalty of $(6 - 1)/(24 - 1) \approx 0.22$, which averaged with three un-generalised attributes at penalty 0 gives an NCP of 0.054, matching the $k = 10$ row of Table 7. A compliance reviewer can therefore reproduce the number by hand rather than trusting an opaque score.

3.9 Anonymised re-detection and experimental protocol

Crucially, detection is re-run on the anonymised data using only anonymised columns, with the feature vector rebuilt from generalised actions, sensitivity classes and retained flags, aggregated per pseudonym. This measures the operationally relevant quantity: how well an analyst could detect insiders seeing only the anonymised log. For each $k \in \{2, 5, 10, 20\}$ the pipeline records the selected generalisation levels, the achieved k , the number and mean size of equivalence classes, the suppression rate, the NCP and the full suite of detection metrics, treating the raw baseline as the $k = 1$ reference point.

3.10 Implementation and reproducibility

The system is implemented in Python 3. Data is held in a relational store with two tables: `employees`, carrying identity, department, role, seniority and the ground-truth insider flag, and `unified_log`, carrying one row per event with its timestamp, activity type, resource, sensitivity, action, after-hours and external flags, and data volume. Feature engineering and anonymisation use pandas, the detector is the scikit-learn Isolation Forest, and the dashboard uses Streamlit. Every stochastic component is driven by a fixed seed, so a reviewer running the pipeline obtains exactly the numbers reported here. The k -verification and NCP routines sit in an independent module, so a compliance reviewer can verify the achieved k without trusting the anonymiser, and a different detector or privacy model can be substituted at one well-defined interface.

4 RESULTS

4.1 Dataset characteristics

The generator produced 850,853 log events across 500 employees over 180 days, of which 25 employees are malicious insiders responsible for 9,206 events, just over one percent of the log. The heterogeneous normal population behaves as intended: several benign archetypes produce genuinely outlying feature values, visible in the wide spread of the normal class in Figure 1D and in the normal employee ranked second in Figure 1G, confirming that the task is not trivially separable.

4.2 Baseline detection on raw logs (O2)

On the raw log the Isolation Forest cleanly separates insiders from normal staff, correctly identifying 22 of 25 insiders with only 3 false positives out of 475 normal employees, giving precision, recall and F1 all equal to **0.88** and an AUC-ROC of **0.995** (Table 6). This comfortably exceeds the F1 target of 0.75 for O2 and establishes the ceiling against which every anonymised configuration is compared.

In operational terms, when the system accuses someone it is right 88% of the time and it catches 88% of real insiders, while an AUC-ROC of 0.995 means the score ranks insiders above normal staff almost perfectly,

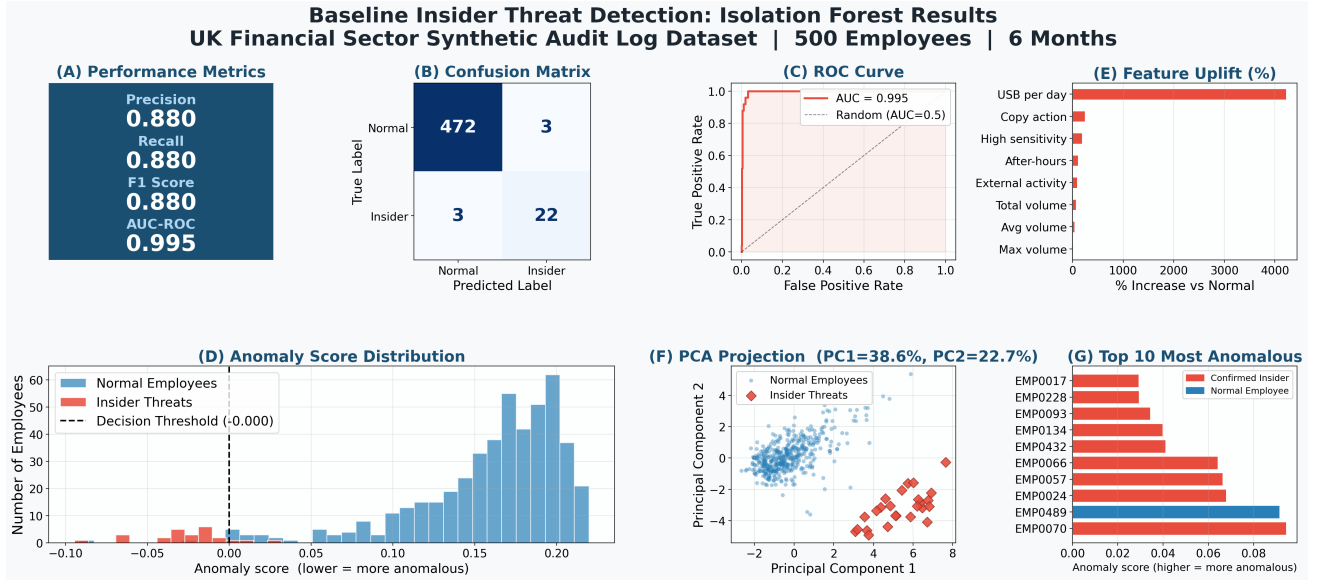


Figure 1. Baseline Isolation-Forest diagnostics on the raw log. Seven views of the same single run over 500 entities, establishing the $k = 1$ reference point. **(A) Performance metrics.** The four headline scores at the fixed 5% operating point. Precision, recall and F1 coincide at 0.88 for the structural reason given in Section 3.5; AUC-ROC of 0.995 is the only threshold-free figure and is therefore the one to read. **(B) Confusion matrix.** Rows are ground truth, columns predictions. The 472 true negatives dominate, and the off-diagonal cells are equal at 3 each, again a consequence of the fixed operating point. **(C) ROC curve.** True-positive rate against false-positive rate over every threshold. The curve rises almost vertically to 1.0 before the false-positive rate reaches 0.05, so the detector recovers nearly all insiders while accusing almost no one; the grey diagonal is random guessing. **(D) Anomaly-score distribution.** Insiders (red) sit at the low, anomalous end while normal staff (blue) form a long right tail; the dashed line is the 5% decision threshold. The narrow band where the colours overlap is where the six errors are generated, and it is this overlap that widens as k increases. **(E) Feature uplift.** Percentage increase of each feature for insiders relative to normal staff. USB usage per day dominates at over 4000%, followed by copy-action and high-sensitivity ratios, while the data-volume features contribute almost nothing, the intended consequence of designing exfiltration to occur in small chunks. **(F) PCA projection.** The feature space standardised and reduced to two components explaining 61.3% of variance. Insiders (red diamonds) form a distinct cluster to the lower right, confirming they are separable on behavioural aggregates alone; the few blue points drifting toward them are legitimate-outlier archetypes. **(G) Ten most anomalous entities.** Ranked by anomaly score. Nine are confirmed insiders; the exception, EMP0489, is a legitimate-outlier archetype ranked second overall, showing that the engineered false-positive pressure is real rather than nominal.

against 1.0 for flawless ordering and 0.5 for random. The three missed insiders are the subtlest exfiltrators, barely departing from the busy-analyst and IT-administrator archetypes, which are exactly the hard cases the dataset was designed to include.

4.3 What drives detection

The feature-uplift panel (Figure 1E) shows which behaviours the detector relies on, and the ordering aligns with domain intuition for financial-sector exfiltration, where removable media and repeated copying of sensitive files are the classic signatures. This gives the detector an interpretable basis rather than an opaque score, which matters for a compliance audience.

4.4 k -anonymity verification (O3)

The module satisfied the target k at all four configurations, verified programmatically as the minimum equivalence-class size over the QIDs per Equation (4). Table 7 lists the achieved k , equal to the target in every case, the generalisation levels selected by the lattice search, and the resulting class structure. Increasing k collapses the log into fewer, larger classes, from 55,684 of mean size 14.8 at $k = 2$ to 4,442 of mean size 185.7 at $k = 20$, satisfying O3.

4.5 Privacy and utility tradeoff (O4)

Table 7 and Figure 2 report the central empirical result. Three findings stand out.

First, ranking quality is highly robust to anonymisation: AUC-ROC falls only from the raw 0.995 to 0.989 at $k = 10$, and even at $k = 20$ remains a strong 0.954. An analyst working solely from the anonymised log can therefore still rank insiders above normal staff almost as well as with raw data, even when records are indistinguishable in groups of twenty.

Second, thresholded F1 degrades gracefully rather than catastrophically, falling from 0.88 raw to 0.72 at $k = 20$. Across the entire privacy range the detector loses at most four insiders, from 22 caught down to 18.

Third, information loss is not monotone in k , because the module minimises loss at each level independently: $k = 5$ generalises identity to division (NCP 0.060), $k = 10$ finds a 6-hour time window cheaper (NCP 0.054), and $k = 20$ generalises resource to sensitivity class (NCP 0.082). Detection utility, by contrast, falls monotonically,

Table 7. Privacy and utility tradeoff across k -anonymity configurations. The $k = 1$ row is the raw baseline. Generalisation levels are given as (identity, time, resource, action); higher is more generalised. NCP is the Normalised Certainty Penalty (information loss); Supp. is the suppression rate.

k	Gen. (i,t,r,a)	Classes	Mean	NCP	Supp.	Prec.	Rec.	F1	AUC
1 (raw)	(0,0,0,0)	n/a	n/a	0.000	0.0%	0.88	0.88	0.88	0.995
2	(0,0,0,0)	55,684	14.8	0.000	2.9%	0.80	0.80	0.80	0.993
5	(1,0,0,0)	20,135	40.3	0.060	4.5%	0.76	0.76	0.76	0.990
10	(0,1,0,0)	9,817	82.4	0.054	4.9%	0.76	0.76	0.76	0.989
20	(0,0,1,0)	4,442	185.7	0.082	3.1%	0.72	0.72	0.72	0.954

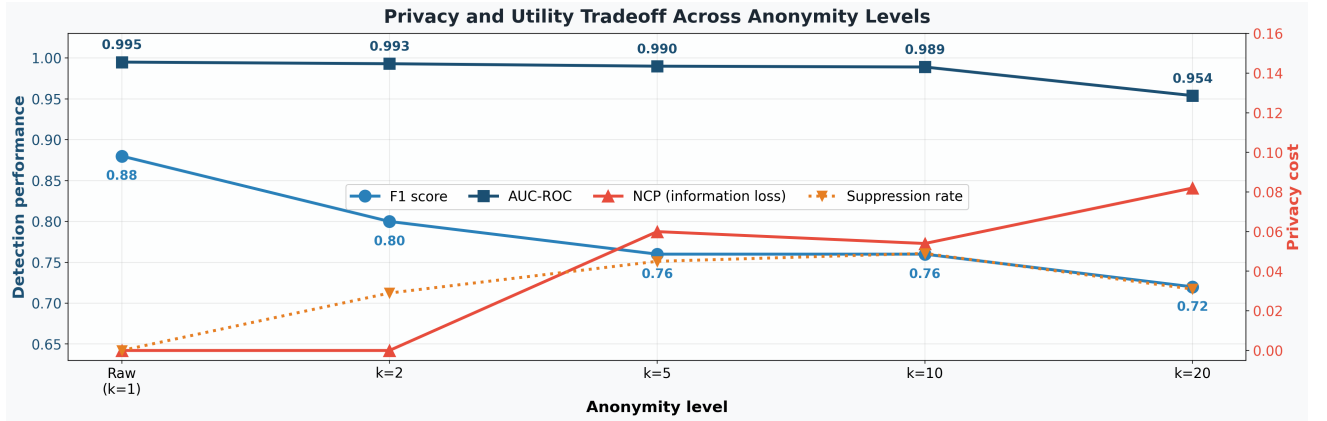


Figure 2. Privacy and utility tradeoff across anonymity levels. The central result of the project, plotted on twin vertical axes so that what is gained and what is paid can be read against each other. The horizontal axis is the anonymity level, ordered from the raw baseline ($k = 1$, no protection) to $k = 20$ (strongest protection); it is categorical, so the five configurations are evenly spaced rather than scaled by k . *Left axis, in blue, detection performance.* AUC-ROC (dark squares) measures, without any threshold, how well the score ranks insiders above normal staff. It is almost flat, falling only from 0.995 to 0.989 across $k = 1$ to $k = 10$ and reaching 0.954 at $k = 20$; this near-horizontal line is the single most important feature of the figure, because it says the ordering of suspicion survives anonymisation nearly intact. F1 (light circles) is the thresholded measure at the fixed 5% operating point and declines visibly from 0.88 to 0.72. The widening gap between the two blue curves is the AUC/F1 divergence of Section 5: most of the F1 decline is a thresholding artefact rather than lost discriminative power. *Right axis, in red and orange, privacy cost.* NCP (red triangles) is the Normalised Certainty Penalty, the syntactic information loss from generalisation. It is *non-monotone*: 0 at $k = 2$, 0.060 at $k = 5$, back down to 0.054 at $k = 10$, then 0.082 at $k = 20$. This zig-zag is not noise, since the module re-solves the lattice independently at every k , and at $k = 10$ a six-hour time window happens to be cheaper than the identity generalisation chosen at $k = 5$. **Suppression rate** (orange dotted) is the fraction of records discarded because their class stayed below k ; it stays within the 5% budget throughout, peaking at 4.9%. The practical reading is the vertical slice at $k = 10$: a far stronger guarantee than $k = 2$ for an AUC cost of 0.004, at lower information loss than $k = 5$.

because the guarantee strengthens monotonically regardless of which attribute is generalised. The gap between the smooth utility decline and the jagged NCP curve is itself a useful finding: NCP measures syntactic loss, whereas utility depends on *which* information is lost relative to the discriminative features, so the two are related but not interchangeable.

Table 8 decomposes the outcome into the raw counts underlying the metrics, and Figure 3 visualises the same trend. It is informative to ask *which* insiders are lost as k rises. In every case they are the subtlest exfiltrators, already close to the busy-analyst and IT-administrator archetypes on raw data and sitting near the decision threshold. Anonymisation does not blind the detector to obvious insiders; it erodes the margin on borderline ones, which is why per-configuration threshold recalibration recovers most of the loss. Insiders with strong USB and copy signatures remain flagged at every level, because those aggregate rates survive generalisation of the categorical quasi-identifiers.

4.6 The interactive analysis tool

Beyond the batch experiment, the pipeline is exposed through a Streamlit dashboard that constitutes the demonstrable artefact. It lets an analyst load the unified log, view raw and anonymised sample tables side by side, select an anonymity level and see the resulting equivalence-class structure and suppression rate, and run detection on either view, with detected entities listed by anomaly score and the tradeoff plotted live as k changes. Presenting both views together makes the effect tangible: exact timestamps and identities disappear while the behavioural summary that drives detection survives. The dashboard deliberately surfaces privacy metrics alongside detection metrics, so the tradeoff is never hidden from the operator.

Table 8. Per-configuration confusion counts (of 25 insiders and 475 normal employees). TP caught, FN missed, FP false alarms.

Config	TP	FN	FP	Precision	Recall
Raw	22	3	3	0.88	0.88
$k=2$	20	5	5	0.80	0.80
$k=5$	19	6	6	0.76	0.76
$k=10$	19	6	6	0.76	0.76
$k=20$	18	7	7	0.72	0.72

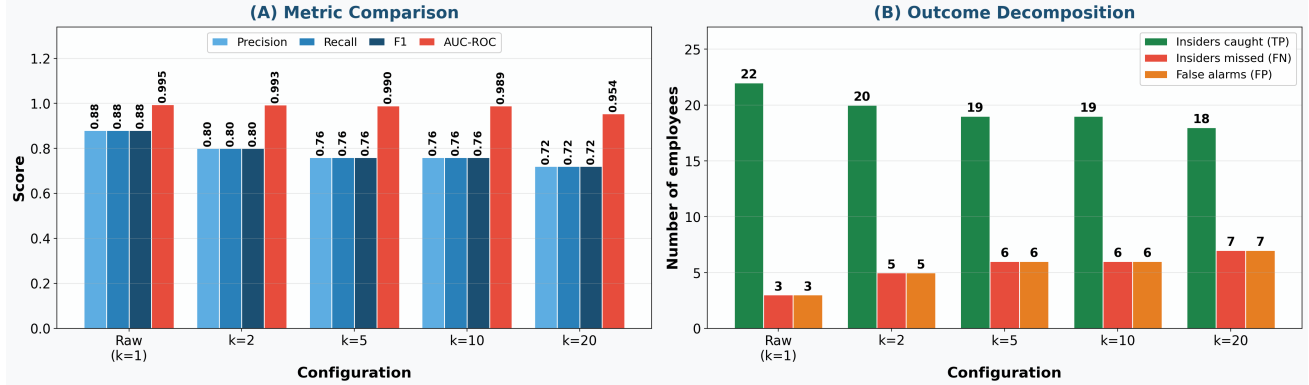


Figure 3. Detection outcome across the raw baseline and the four anonymity levels. The same five configurations as Figure 2, shown as bars so that magnitudes can be compared directly rather than read off a trend line. **(A) Metric comparison.** Four bars per configuration. The three blue bars, precision, recall and F1, are identical within every group, the visual signature of the fixed 5% operating point described in Section 3.5, and step down in unison from 0.88 to 0.72. The red AUC-ROC bar barely changes height, remaining above 0.95 even at $k = 20$. The contrast between the stepping blue bars and the flat red one is the same divergence Figure 2 shows as curves, reproduced here because the bar form makes the size of the difference easier to judge. **(B) Outcome decomposition.** The identical results as counts of people rather than scores, which is the form an operational reader cares about. Green is insiders caught, red insiders missed, orange false alarms. Across the whole privacy range the green bar falls only from 22 to 18, while red and orange rise in lockstep from 3 to 7, again because the fixed operating point forces false positives to equal false negatives. No step produces an abrupt collapse, which is the granular evidence that degradation is graceful, and since false alarms rise only from three to six over the recommended range, the additional review burden is negligible.

4.7 Meeting the success measures

Every success measure of Section 1 is met: twenty-five sources synthesised (O1); a baseline F1 of 0.88 against the 0.75 target with documented precision, recall and AUC (O2); k -anonymity verified programmatically at all four configurations (O3); a complete tradeoff curve with a recommended configuration (O4); and the GDPR mapping in the next section (O5).

5 EVALUATION AND DISCUSSION

5.1 Interpreting the tradeoff and a recommended configuration

The headline conclusion is that strong, provable anonymity and effective insider detection are not mutually exclusive. Across a tenfold increase in anonymity, from $k = 2$ to $k = 20$, F1 falls by only 0.08 and AUC by 0.04. Insider signal in audit data is carried by aggregate behavioural rates such as USB usage, copy ratios and after-hours proportion, and these survive generalisation of the categorical QIDs far better than a re-identification attack does: anonymisation blurs *who* and *exactly when* but preserves *how much* and *what kind*, which is what the detector consumes.

Within this space, $k = 10$ is the recommended deployment configuration. It offers a materially stronger guarantee than $k = 5$, every record being indistinguishable from at least nine others rather than four, yet incurs no loss of F1 (both 0.76), a negligible AUC difference (0.989 against 0.990) and in fact marginally lower information loss, so it dominates $k = 5$ on almost every axis. We would reserve $k = 20$ for particularly sensitive deployments or longer retention, accepting the AUC drop to 0.954, and treat $k = 2$ as insufficient, since a re-identification probability of one half offers little protection despite its near-zero utility cost.

5.2 GDPR compliance assessment (O5)

The value of expressing anonymity as the tunable parameter k is that it converts an abstract legal question into an engineering decision. Table 9 maps each configuration to the GDPR articles it does and does not satisfy, and the reasoning is as follows.

The raw log is unambiguously personal data and satisfies none of the minimisation-oriented provisions.

Table 9. GDPR posture by configuration. ✓ denotes satisfied, ✗ not satisfied, and ~ partially or conditionally satisfied.

GDPR provision	Raw	$k=2$	$k=5-10$	$k=20$
Art. 4 / Recital 26 (anonymisation)	✗	✗	~	✓
Art. 5(1)(c) data minimisation	✗	~	✓	✓
Art. 5(1)(e) storage limitation	✗	~	✓	✓
Art. 25 data protection by design	✗	✓	✓	✓
Art. 32 security of processing	~	✓	✓	✓

Pseudonymisation alone, as at $k = 2$, does not exit GDPR scope, since Recital 26 is explicit that pseudonymised data remains personal data. The critical transition occurs at moderate k : at $k = 5$ to $k = 10$, with every record indistinguishable within a class of at least five to ten and direct identifiers and exact timestamps removed, the data has a credible though never absolute claim to satisfy Articles 5(1)(c) and 5(1)(e), and the design embodies Articles 25 and 32. Only at $k = 20$ does it approach the Recital 26 threshold at which it might fall outside the Regulation entirely. The honest caveat [12, 13, 24] is that k -anonymity bounds identity but not attribute disclosure, so a fuller deployment would layer ℓ -diversity or t -closeness, and no technical measure removes the need for a documented lawful basis and a Data Protection Impact Assessment.

A second caveat qualifies the strongest reading of Table 9 and deserves stating plainly. Detection operates on per-employee aggregates, so every record belonging to one individual carries the same salted pseudonym for the whole 180-day window. That pseudonym defeats direct identification but preserves complete *linkability* across an individual's records, one of the three residual risks the Article 29 Working Party requires to be assessed separately from singling out [24], and under Recital 26 it remains personal data for as long as the salt is retrievable. The posture in Table 9 should therefore be read as applying to the generalisation of the quasi-identifiers, not as a claim that the log leaves the scope of the Regulation merely by reaching a given k . Two cheap mitigations follow: hold the salt separately from the log and destroy it when the analysis window closes, and rotate the pseudonym between windows so linkage cannot accumulate. With those controls the $k = 20$ configuration has a defensible claim to Recital 26 anonymity; without them, the accurate characterisation is strong pseudonymisation with a bounded, measured disclosure risk on the quasi-identifiers, a materially weaker but still valuable position.

5.3 Practical deployment guidance

Four recommendations follow for a regulated firm. Detection should be driven from the anonymised log, since this costs little detective power while materially reducing privacy risk. The anonymity level should be a governed parameter documented in the firm's Data Protection Impact Assessment, with $k = 10$ a reasonable default. Retention should be tied to k , because a higher k reduces re-identification risk and can justify a longer analysis window under storage limitation, whereas raw data should be retained only briefly. Finally, the detection cut-off should be recalibrated per configuration rather than fixed. The cost-benefit calculus is favourable: false alarms rise only from three to six across the whole range, so the analyst review burden barely changes, while the reduction in privacy risk is substantial and, unlike a policy control, provable and auditable.

5.4 Critical reflection on the artefact

Judged against its objectives the artefact is successful: all five were met, the baseline exceeded its target, k -anonymity was formally verified, and a complete tradeoff curve with a justified recommendation was produced. The design choice that most improved the work was investing in a hard dataset: an earlier iteration produced insiders so blatant that detection was perfect at every k and the curve was flat, so engineering subtle insiders and legitimate-outlier personas is what made the baseline land at a realistic 0.88 and the tradeoff meaningful. The clearest reflective insight is the divergence between AUC and F1, which Section 6 returns to. Most of the apparent F1 loss is a thresholding artefact, since at higher k the score distribution compresses and a fixed 5% cut-off becomes mis-calibrated, so recovering it is as simple as recalibrating per configuration.

5.5 Ethical implications revisited

The results allow the dual-use concern of Section 1 to be revisited with evidence. Because effective detection persists at moderate k , the project removes a common excuse for over-retention: an organisation can no longer argue that privacy protection would cripple its ability to detect insiders, which cuts against invasive monitoring

rather than enabling it. The finding could nonetheless be misused to argue that, since anonymised monitoring still works, monitoring should be extended more broadly. The defence is built into the GDPR mapping: even a well-anonymised system remains subject to necessity and proportionality, and Section 5.2 is explicit that a technical guarantee does not substitute for a lawful basis, purpose limitation, or a Data Protection Impact Assessment. The artefact makes privacy-respecting monitoring more achievable, but it cannot adjudicate whether a monitoring programme is justified in the first place; that remains a governance decision for which the tool supplies evidence rather than a verdict.

5.6 Limitations and threats to validity

Six limitations bound the strength of the claims, set out in order of how far they qualify the central finding.

Construct validity: synthetic data. Real financial logs cannot be lawfully released, and synthesis permits known ground truth and controlled difficulty, but the numbers depend on the generator’s assumptions. Because behaviour is drawn from parametric distributions, the normal population is almost certainly more homogeneous than a real workforce, where team-level, seasonal and project-driven variation would widen the normal class and depress precision at every k . The absolute figures should therefore be read as an upper envelope; the *shape* of the tradeoff, which is the actual claim, rests only on the weaker assumption that insider signal is carried by aggregate rates [1, 18].

Internal validity: design of the anonymisation. Global recoding over four QIDs with a 5% suppression budget is one design among many, and a different QID set, hierarchy or budget would shift the curve. The hierarchies are hand-designed rather than learned, so the lattice search finds the cheapest configuration *within a design choice* rather than the globally optimal generalisation, and local recoding [15] could reduce loss further.

External validity: one detector, one dataset. The Isolation Forest is, by construction, the detector family most favourable to the finding, since it consumes aggregate features exclusively. A sequence model reading event order and exact inter-arrival times would have far more to lose from timestamp generalisation, so the result should not be assumed to transfer without testing on other detectors and on the CERT corpus [18].

Statistical limitation: single seeded run. Each configuration comes from one seeded run rather than repeated trials with confidence intervals. With only 25 insiders, one additional miss moves recall by four percentage points, so differences of that order between adjacent k values sit within plausible run-to-run noise. The monotone trend across the full range is robust; the fine ranking of neighbouring configurations is not.

Scope limitation: threat and privacy models. k -anonymity bounds re-identification by QID linkage and no other risk, so attribute disclosure within a homogeneous class, and the inference and linkability risks emphasised by the Article 29 Working Party [24], remain outside the guarantee. Negligent and compromised insiders are excluded, and the batch, at-rest design says nothing about real-time streaming detection.

Evaluation limitation: fixed operating point. All configurations share a fixed 5% contamination threshold, which is the main cause of the apparent F1 decline and which, as shown in Section 3.5, forces precision, recall and F1 to coincide. That threshold is also set to the true insider prevalence, which a real deployment would not know in advance. Using the same value everywhere does not bias the comparison across k , which is the object of study, but the F1 figures are a conservative lower bound for a tuned deployment while the absolute precision and recall are an optimistic bound rather than an operational forecast [8].

5.7 Generalisability and the choice of privacy technology

Although the experiment uses one synthetic dataset and one detector, the mechanism behind the central finding is general: any detector that, like the Isolation Forest, consumes per-entity aggregate features rather than exact event attributes should inherit the same robustness of ranking under anonymisation. The magnitude of the tradeoff will vary with how much insider signal is concentrated in rare quasi-identifier combinations, so an institution whose insiders rely on removable media, an aggregate channel, might see smaller utility loss than one whose insiders depend on rare specific resources. The framework itself, namely anonymise to a verified k , re-detect on the anonymised view, and report both privacy and utility, is dataset- and detector-agnostic.

The results also bear on whether k -anonymity was the right mechanism. Its principal weakness, attribute disclosure, is real: if every member of an equivalence class shares the same sensitive value, an adversary learns it without re-identifying anyone, which is why layering ℓ -diversity or t -closeness is recommended for any real deployment. Against this it has two advantages the results bear out. It preserves truthful, per-record data, which is why the anomaly structure and hence the AUC survive so well, and it yields a single legible parameter that maps onto a compliance narrative, which a noise-based mechanism does not. The preservation of ranking quality is therefore a finding about k -anonymity specifically: it is the truthfulness of the generalised records, not merely their coarseness, that keeps detection viable.

5.8 Contribution relative to prior work

Prior anonymisation research [10, 12, 14] evaluates privacy against re-identification on static microdata; prior insider-detection research [1, 22, 5] evaluates detection on raw data. This dissertation closes the loop between them: ranking-based insider detection proves substantially more robust to k -anonymisation than re-identification risk is, which reframes the tradeoff from a zero-sum conflict into a tractable tuning problem.

6 CONCLUSION AND FUTURE WORK

This dissertation set out to determine at what level of anonymisation an audit log becomes defensible under the GDPR, and what that costs in insider-threat detection. Building an end-to-end pipeline over a purpose-built financial-sector dataset, we established a strong raw baseline with an F1 of 0.88 and an AUC of 0.995, implemented and formally verified a k -anonymity generalisation module at $k \in \{2, 5, 10, 20\}$, and measured the full tradeoff. The evidence supports a clear and somewhat optimistic answer: effective detection and provable anonymity coexist. Ranking quality remains above 0.95 AUC even at $k = 20$, thresholded F1 degrades only gracefully, and $k = 10$ emerges as a sweet spot delivering meaningful GDPR-aligned anonymity at negligible utility cost. The practical implication is concrete: financial institutions need not choose between monitoring for insider threats and respecting workforce privacy, since they can select an anonymity level as an explicit, defensible parameter and retain most of their detective power.

Returning to the research question, the study gives it a quantified answer. Anonymisation becomes GDPR-defensible in a meaningful sense at k between five and ten, where direct identifiers and exact timestamps are removed and every record hides in a class of at least that size, and the cost of reaching $k = 10$ is a fall in F1 from 0.88 to 0.76 with AUC essentially unchanged at 0.989. Put the other way round, the price of provable, moderate anonymity is close to nothing in a rank-and-review workflow, and being able to state that price as a number is itself part of the contribution.

All four contributions claimed in Section 1 are discharged: the pipeline and interactive tool constitute the *constructive artefact*; Table 7 and Figure 2 are the *empirical tradeoff characterisation*; Table 9 is the *GDPR mapping* that converts a legal question into a reviewable engineering parameter; and the *dataset generator* embeds subtle insiders alongside legitimate-outlier personas, carrying the transferable methodological lesson that the difficulty of the underlying task is not incidental to a privacy and utility result but constitutive of it.

Two findings generalise beyond the specific numbers. The first is the divergence between AUC and F1. Reporting only the thresholded metric would have supported the pessimistic conclusion that anonymisation costs sixteen points of performance, whereas the near-flat AUC shows the ranking is substantially intact and most of the apparent loss is a thresholding artefact. Since insider triage is a rank-and-review workflow rather than an automated block, this is the difference between a result that discourages privacy engineering and one that enables it, and the caution applies to any evaluation of a privacy mechanism against a rare-event detector. The second is the mechanism behind that robustness: aggregate behavioural rates are statistics over many events, perturbed only weakly by generalising the categorical attributes of individual events, whereas linkability, which is what a re-identification attack consumes, is destroyed by the same operation. Privacy and utility draw on different properties of the data, which is why they are not the zero-sum pair the framing assumes.

The claim is nonetheless bounded. The evidence comes from one synthetic dataset, one detector family and one privacy model, evaluated at a fixed operating point from a single seeded run, and Section 5.6 sets out where each choice could move the result. What the study establishes firmly is the existence and shape of a workable middle path; its exact position for a given institution remains an empirical exercise on that institution's own data.

6.1 Future work

Future work follows directly from those limitations, and is set out below in descending order of how much it would strengthen the central claim.

Validation beyond the synthetic corpus. The highest priority is replication on the CERT insider-threat corpus [18] and, ideally, on a real institutional log under a data-processing agreement. This is the only way to test the construct-validity limitation directly, since it substitutes an independently generated, more heterogeneous normal population for the parametric one used here. The concrete expectation, which the experiment would confirm or refute, is that absolute precision falls at every k while the *shape* of the tradeoff curve is preserved; a divergence in shape rather than level would materially weaken the claim and would be the most informative negative result available.

Detector diversity, especially sequence models. The AUC-robustness finding should be re-tested with an autoencoder, a one-class SVM and, most importantly, a sequence model such as an LSTM or transformer over the event stream. This is the sharpest available test, because a sequence model consumes event order and inter-arrival times and so has far more to lose from timestamp generalisation than an aggregate-feature detector. If ranking quality proved robust there too, the finding would generalise well beyond the design studied here; if not, the

recommendation becomes detector-conditional, itself a useful result for a firm choosing a detection stack.

Stronger privacy models. Layering ℓ -diversity [12] or t -closeness [13] over the existing equivalence classes would bound attribute as well as identity disclosure, closing the main acknowledged gap in the guarantee. Because both operate on the class structure the module already computes, the extension is architecturally cheap; the interesting question is how much extra information loss the constraint costs at a fixed k , and whether utility degrades faster than under k -anonymity alone. A complementary direction is a direct comparison against a differentially private treatment of the same features [23], which Section 2.6 predicts would damage the rare-event signal considerably more, quantifying a tradeoff currently argued only on principle.

Reducing information loss and recalibrating the operating point. Replacing global with utility-based local recoding [15] should achieve the same verified k at lower NCP, and would test whether the detection utility recovered tracks the syntactic loss avoided, given that the two were shown here to be related but not interchangeable. Independently, per-configuration threshold recalibration, run across repeated seeds with reported confidence intervals, would both recover the F1 lost to distribution compression and address the single-run statistical limitation, converting the qualitative claim that most of the F1 decline is a thresholding artefact into a measured one.

Operational and regulatory extension. Two further steps would move the work towards deployment. The first is a streaming variant in which anonymisation sits on the latency path of a real-time detector, raising questions the batch design avoids entirely, notably how to form equivalence classes over an unbounded stream and how much detection delay the guarantee costs. The second is pseudonym lifecycle management, namely salt rotation between windows and separated salt custody, which Section 5.2 identifies as the single change that would most strengthen the Recital 26 argument; how much cross-window detective power such rotation sacrifices is an open and practically important question.

Each step is modest and well-scoped on the pipeline established here. Together they would move the central claim from a demonstrated possibility to a calibrated engineering guideline, which is what a regulated firm would need before setting k in production.

REFERENCES

- [1] Ivan Homoliak, Flavio Toffalini, Juan Guarnizo, Yuval Elovici, and Martín Ochoa. 2019. Insight into Insiders and IT: A Survey of Insider Threat Taxonomies, Analysis, Modeling, and Countermeasures. *ACM Computing Surveys* 52, 2 (2019), 1–40.
- [2] Malek Ben Salem, Shlomo HersHKop, and Salvatore J. Stolfo. 2008. A Survey of Insider Attack Detection Research. In *Insider Attack and Cyber Security*. Springer, 69–90.
- [3] Liu Liu, Olivier De Vel, Qing-Long Han, Jun Zhang, and Yang Xiang. 2018. Detecting and Preventing Cyber Insider Threats: A Survey. *IEEE Communications Surveys & Tutorials* 20, 2 (2018), 1397–1417.
- [4] Varun Chandola, Arindam Banerjee, and Vipin Kumar. 2009. Anomaly Detection: A Survey. *ACM Computing Surveys* 41, 3 (2009), 1–58.
- [5] Aaron Tuor, Samuel Kaplan, Brian Hutchinson, Nicole Nichols, and Sean Robinson. 2017. Deep Learning for Unsupervised Insider Threat Detection in Structured Cybersecurity Data Streams. In *AAAI Workshop on Artificial Intelligence for Cyber Security*.
- [6] Philip A. Legg, Oliver Buckley, Michael Goldsmith, and Sadie Creese. 2017. Automated Insider Threat Detection System Using User and Role-Based Profile Assessment. *IEEE Systems Journal* 11, 2 (2017), 503–512.
- [7] Fei Tony Liu, Kai Ming Ting, and Zhi-Hua Zhou. 2008. Isolation Forest. In *Proceedings of the IEEE International Conference on Data Mining (ICDM)*. 413–422.
- [8] Robin Sommer and Vern Paxson. 2010. Outside the Closed World: On Using Machine Learning for Network Intrusion Detection. In *Proceedings of the IEEE Symposium on Security and Privacy*. 305–316.
- [9] Pierangela Samarati. 2001. Protecting Respondents’ Identities in Microdata Release. *IEEE Transactions on Knowledge and Data Engineering* 13, 6 (2001), 1010–1027.
- [10] Latanya Sweeney. 2002. k -Anonymity: A Model for Protecting Privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems* 10, 5 (2002), 557–570.
- [11] Kristen LeFevre, David J. DeWitt, and Raghu Ramakrishnan. 2005. Incognito: Efficient Full-Domain K -Anonymity. In *Proceedings of the ACM SIGMOD International Conference on Management of Data*. 49–60.
- [12] Ashwin Machanavajjhala, Daniel Kifer, Johannes Gehrke, and Muthuramakrishnan Venkatasubramanian. 2007. l -Diversity: Privacy Beyond k -Anonymity. *ACM Transactions on Knowledge Discovery from Data* 1, 1 (2007), 3.
- [13] Ninghui Li, Tiancheng Li, and Suresh Venkatasubramanian. 2007. t -Closeness: Privacy Beyond k -Anonymity and l -Diversity. In *Proceedings of the IEEE International Conference on Data Engineering (ICDE)*. 106–115.
- [14] Benjamin C. M. Fung, Ke Wang, Rui Chen, and Philip S. Yu. 2010. Privacy-Preserving Data Publishing: A Survey of Recent Developments. *ACM Computing Surveys* 42, 4 (2010), 1–53.
- [15] Jian Xu, Wei Wang, Jian Pei, Xiaoyuan Wang, Baile Shi, and Ada Wai-Chee Fu. 2006. Utility-Based Anonymization Using Local Recoding. In *Proceedings of the ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*. 785–790.
- [16] Isabel Wagner and David Eckhoff. 2018. Technical Privacy Metrics: A Systematic Survey. *ACM Computing Surveys* 51, 3 (2018), 1–38.
- [17] Marina Sokolova and Guy Lapalme. 2009. A Systematic Analysis of Performance Measures for Classification Tasks. *Information Processing & Management* 45, 4 (2009), 427–437.
- [18] Joshua Glasser and Brian Lindauer. 2013. Bridging the Gap: A Pragmatic Approach to Generating Insider Threat Data. In *Proceedings of the IEEE Security and Privacy Workshops*. 98–104.
- [19] Ann Cavoukian. 2011. *Privacy by Design: The 7 Foundational Principles*. Information and Privacy Commissioner of Ontario, Canada.
- [20] Paul Voigt and Axel von dem Bussche. 2017. *The EU General Data Protection Regulation (GDPR): A Practical Guide*. Springer International Publishing.
- [21] Colin Tankard. 2016. What the GDPR Means for Businesses. *Network Security* 2016, 6 (2016), 5–8.
- [22] Shuhan Yuan and Xintao Wu. 2021. Deep Learning for Insider Threat Detection: Review, Challenges and Opportunities. *Computers & Security* 104 (2021), 102221.
- [23] Cynthia Dwork and Aaron Roth. 2014. The Algorithmic Foundations of Differential Privacy. *Foundations and Trends in Theoretical Computer Science* 9, 3–4 (2014), 211–407.
- [24] Article 29 Data Protection Working Party. 2014. *Opinion 05/2014 on Anonymisation Techniques (WP216)*. European Commission, Brussels.
- [25] Information Commissioner’s Office. 2023. *Employment Practices and Data Protection: Monitoring Workers*. ICO, Wilmslow, UK.